Política de Segurança da Informação

Última atualização: 2 de novembro de 2026

1. Objetivo e abrangência

Esta Política define as regras e os controles que a TECSO TECNOLOGIA DE INFORMATICA LTDA (CNPJ 52.609.371/0001-79) adota para proteger a confidencialidade, a integridade e a disponibilidade das informações tratadas pelo Ofertio, incluindo dados de usuários, credenciais de integrações e dados recebidos de plataformas parceiras. Ela se aplica a todos os ambientes do Ofertio (homologação e produção), aos seus sistemas, às pessoas com acesso a eles e aos fornecedores que tratam dados em nosso nome.

2. Princípios

- **Confidencialidade:** a informação só é acessada por quem precisa dela para prestar o serviço.
- **Integridade:** a informação é protegida contra alterações indevidas.
- **Disponibilidade:** o serviço e os dados ficam acessíveis a quem tem direito, quando necessário.
- **Menor privilégio e necessidade:** cada pessoa, sistema e integração recebe apenas o acesso mínimo necessário.
- **Privacidade desde a concepção:** segurança e proteção de dados são consideradas em cada nova funcionalidade, em conformidade com a LGPD.

3. Governança e responsabilidades

- O responsável pela segurança da informação e encarregado de dados (DPO) é **Rony Faria de Araujo**.
- Ele aprova esta Política, acompanha a sua aplicação, trata incidentes e conduz a revisão periódica dos controles.
- Todas as pessoas com acesso aos sistemas do Ofertio devem conhecer e cumprir esta Política e manter sigilo sobre as informações a que tiverem acesso.

4. Controle de acesso

- O acesso à plataforma exige autenticação individual, com e-mail e senha ou por login social (Google).
- As senhas são armazenadas apenas em formato de hash irreversível (BCrypt); nunca em texto puro.
- As permissões são definidas por perfil. Funções administrativas, como o cofre de chaves e as integrações globais, ficam restritas a perfis com permissão específica.
- Os dados de cada cliente são isolados por inquilino (multi-tenant): um cliente não acessa dados de outro.
- Acessos administrativos e alterações sensíveis são registrados em trilha de auditoria, com usuário, data, hora e origem.
- Acessos são revistos e removidos quando deixam de ser necessários.

5. Classificação da informação, proteção de dados e criptografia

5.1. Classificação da informação

Toda informação tratada pelo Ofertio é classificada em um dos níveis abaixo, e os controles são aplicados conforme o nível:

- **Pública:** informação destinada à divulgação, como estas políticas, os Termos de Uso e as páginas públicas do Ofertio. Pode ser publicada sem restrição, mas só é alterada por pessoas autorizadas.
- **Interna:** informação de operação que não identifica pessoas, como documentação técnica, configurações não sensíveis e métricas agregadas. Acesso restrito à equipe do Ofertio.
- **Confidencial:** dados pessoais e do negócio dos usuários, como nome, e-mail, celular, endereço de cobrança, lojas conectadas, links, ofertas, cliques e relatórios. Acesso apenas pelo próprio usuário (isolado por inquilino) e pela equipe autorizada, quando necessário para o suporte; tráfego sempre por HTTPS.
- **Restrita (sensível):** senhas, tokens de acesso e de renovação, segredos de aplicações (App Key, App Secret, Client Secret), chaves de criptografia e documentos como CPF/CNPJ. Criptografada em repouso e em trânsito, nunca exibida por completo nem gravada em logs, com acesso restrito a perfis administrativos específicos e registrado na trilha de auditoria.

Na dúvida, a informação é tratada pelo nível mais alto aplicável. O número completo do cartão não é armazenado; a bandeira e os 4 últimos dígitos são tratados como Confidencial.

5.2. Proteção e criptografia

- Todo o tráfego entre usuários, a plataforma e as APIs externas usa HTTPS (TLS).
- Tokens de acesso de plataformas parceiras, senhas de integrações, chaves de API e documentos como CPF/CNPJ são criptografados no banco de dados (ASP.NET Core Data Protection e AES-256).
- Segredos de aplicações (App Key, App Secret, Client Secret) ficam no cofre de chaves da plataforma, criptografados, fora do código-fonte e do repositório.
- Segredos, tokens e senhas nunca são gravados em logs.
- Dados de cartão de pagamento não são armazenados: guardamos apenas a bandeira e os 4 últimos dígitos.
- Coletamos apenas os dados necessários para cada finalidade, conforme a Política de Privacidade.

6. Integrações com plataformas parceiras

- As integrações usam somente APIs oficiais e os fluxos de autorização oficiais (OAuth) de cada plataforma. Não fazemos raspagem de dados nem contornamos mecanismos anti-bot ou captcha.
- Não pedimos nem armazenamos a senha que o usuário usa nas plataformas parceiras.
- Solicitamos apenas os escopos necessários para cada funcionalidade.
- O parâmetro `state` dos fluxos OAuth é criptografado, vinculado ao usuário, de uso único e com validade curta, o que protege contra falsificação de requisições (CSRF) e reutilização.
- Os tokens são renovados automaticamente antes de expirar e deixam de ser usados quando o usuário desconecta a conta. O usuário pode revogar o acesso também no painel da própria plataforma.
- Os dados obtidos das plataformas são usados exclusivamente para prestar o serviço ao usuário que autorizou o acesso, conforme as políticas de cada plataforma.

7. Desenvolvimento e operação seguros

- O código-fonte é mantido em repositório privado com controle de versão e histórico de alterações.

- Toda mudança passa por compilação e testes automatizados antes de ser publicada.
- Os ambientes de homologação (dev.ofertio.com.br) e de produção (ofertio.com.br) são separados, com bancos de dados e credenciais distintos.
- As configurações sensíveis não são versionadas, e as dependências de software são mantidas atualizadas.
- As validações de entrada e as regras de autorização são aplicadas no servidor.

8. Registro e monitoramento

- A aplicação registra eventos de funcionamento e erros, sem dados sensíveis, para diagnóstico e detecção de falhas.
- Ações administrativas ficam na trilha de auditoria.
- Métricas de disponibilidade e desempenho são acompanhadas para identificar comportamentos anormais.

9. Continuidade e cópias de segurança

- O banco de dados de produção e as chaves de criptografia são incluídos em rotina de cópias de segurança, guardadas com acesso restrito.
- As chaves de criptografia são preservadas em cada atualização, para que os dados protegidos continuem legíveis.
- Os procedimentos de restauração são documentados e verificados periodicamente.

10. Gestão de incidentes

1. **Identificação:** qualquer suspeita de incidente deve ser comunicada imediatamente ao responsável pela segurança.
2. **Contenção:** o acesso afetado é bloqueado e credenciais e tokens envolvidos são revogados ou trocados.
3. **Análise e correção:** a causa é investigada, corrigida e documentada.
4. **Comunicação:** quando o incidente puder gerar risco ou dano relevante aos titulares, comunicamos a Autoridade Nacional de Proteção de Dados (ANPD) e os titulares afetados, nos termos do art. 48 da LGPD. As plataformas parceiras afetadas são avisadas conforme as regras de cada uma.
5. **Aprendizado:** os controles são revistos para evitar a repetição.

11. Fornecedores

Fornecedores que tratam dados em nome do Ofertio (hospedagem, e-mail, pagamento) são escolhidos considerando as suas práticas de segurança e privacidade e só recebem os dados necessários para o serviço contratado.

12. Comunicação de vulnerabilidades

Se você identificar uma possível vulnerabilidade no Ofertio, escreva para rony.araujo@gmail.com com uma descrição do problema. Pedimos que não acesse, altere ou divulgue dados de terceiros e que nos dê tempo razoável para corrigir antes de qualquer divulgação pública.

13. Revisão

Esta Política é revista pelo menos uma vez por ano e sempre que houver mudança relevante no Ofertio, na legislação ou nas exigências das plataformas parceiras.

14. Contato

TECSO TECNOLOGIA DE INFORMATICA LTDA — CNPJ 52.609.371/0001-79 — São Paulo - SP
Responsável pela segurança da informação e encarregado de dados: Rony Faria de Araujo — rony.araujo@gmail.com

---